

SECOND THOUGHT

Fraud models score the transaction. We score the **path** to it.

A session-authenticity engine that watches the clickstream an MFS already collects — API calls, screens, timing, and this user's own history — and stops account takeover and scam-coerced transfers **before** POST /transfer executes.

The app is hardened. The **session** is not.

- Obfuscation, OTP auto-fill, VPN detection, Play Integrity — attackers still reverse-engineer the APIs and drive accounts with scripts.
- OTP relay and SIM swap give a stranger a fresh device and a victim's wallet.
- Emulator farms, fake-merchant laundering, personal wallets run as unlicensed agents.
- And the worst case: a scam caller talks a first-time, low-literacy user into sending the money **themselves**. Every transaction model sees a legitimate transfer.

Every MFS already records every tap and every API call. Nobody asks that stream the only question that matters: *is this the owner, using the real app?*

Why a transaction model is too late

By the time POST /transfer reaches a fraud model, the attacker already owns the session. The path there — no screens, no telemetry, 150 ms between calls, a recipient this user has never paid, an amount 6σ above their history — was visible **5–10 events earlier**.

Who is hurt

Customers lose money and trust; upay absorbs disputes, chargebacks and reputational damage; analysts drown in alerts that arrive after the fact.

Score every event. Intervene in proportion. Keep a human in the loop.



Three signal families, ~47 features, zero demographics

Structure: which events, in what order, what is *missing* (the real app always pings telemetry; a transfer without a PIN screen is a path skip).

Timing: gap statistics, sub-300 ms fractions, typing speed, hesitation.

Baseline: hours from *this user's* usual time, amount z-score vs *their* history, recipient novelty, pace vs *their* pace.

Four tiers, never a model-only block

Allow · **Second Thought**: genuine person, scam-like situation → plain Bangla explanation, 30 s cooling, an exit · **Step-up**: likely not the owner → re-verify first · **Hold**: not the genuine app → pause, analyst decides.

Replay Theatre: three sessions, one engine, scored live


Second Thought
 Session-authenticity engine for MFS · scores the path to the transaction, not just the transaction

AUC 0.9998 recall 100% @ 2.0% friction stopped before money 92% API live

Replay Theatre Customer screen Analyst console

Play all three Reset Attack me, live:
 Scripted API Adaptive (human-like timing) OTP-relay takeover Scam-call victim Emulator farm Gambling chain

Load a demo session into a lane...

Genuine user U01476 · elderly

Session risk score **0.000**

Allow human-likeness 1

7	GET /offers (prefetch)	+241ms	0.00
8	POST /telemetry/ping	+404ms	0.00
9	Balance screen	+8.7s	0.00
10	Recharge screen b100	+6.3s	0.00
11	PIN entry	+6.2s	0.00
12	POST /telemetry/heartbeat	+5ms	0.00
13	POST /recharge b100	+418ms	0.00
14	Success screen	+4.6s	0.00
15	POST /telemetry/ping	+481ms	0.00
16	POST /auth/logout	+236ms	0.00

history length fastest gap mean typing speed mean gap

Scripted ATO (reverse-engineered API) U00826 · small_merchant

Session risk score **1.000**

Hold + analyst human-likeness 0 fired at event 1 · money call at 3

1	POST /auth/login	+120ms	0.71
2	GET /recipient/resolve	+175ms	0.99
3	POST /transfer b17,800	+684ms	1.00
4	GET /recipient/resolve	+253ms	1.00
5	POST /transfer b14,300	+691ms	1.00
6	POST /transfer b8,700	+704ms	1.00

rare transition first-ever recipient total amount

Coerced victim on a scam call U00396 · student

Session risk score **0.019**

Second Thought human-likeness 1 fired at event 16 · money call at 16

9	Send Money screen	+1.2s	0.00
10	Recipient entry	+5.9s	0.00
11	GET /recipient/resolve	+300ms	0.00
12	Amount entry b23,700	+7.8s	0.00
13	Confirm screen b23,700	+3.2s	0.00
14	PIN entry	+3.0s	0.00
15	POST /telemetry/heartbeat	+5ms	0.00
16	POST /transfer b23,700	+164ms	0.00
17	Success screen	+2.3s	0.00
18	POST /telemetry/ping	+431ms	0.02

total amount first-ever recipient amount vs history

Left: genuine user, score stays at 0. Middle: scripted ATO — **held at event 1**, before the first /transfer at event 3. Right: coerced victim — genuine device and rhythm, but first-ever recipient and b23,700 → **Second Thought** screen fires on the transfer request. "Attack me" generates a brand-new attack and scores it live.

What the customer sees · what the analyst sees

Second Thought

Session-authenticity engine for MFS - scores the path to the transaction, not just the transaction

AUC 0.9998 recall 100% @ 2.0% friction stopped before money 92% API Live

upay

একটু ভাবুন

আপনি কিভাবে যাচ্ছেন

৳23,700

৳৯৯৮ ৳792424

এই পরিমাণ আপনার ব্যক্তিগত লেনদেনের চেয়ে অনেক বেশি।

আপনি কিভাবে কখনো এই বিষয়ে টাকা পরামর্শ নেননি।

একটু থামুন। কেউ কি কোরে আপনাকে এটি করতে বলেছে? উপায় কর্মীরা কখনো টাকা পরামর্শ নেননি।

বাড়িল করুন, আমি নিশ্চিত বই

কোরে কেউ আমাকে করতে বলেছে

উঁহ, আমি একে চিনি। এগিয়ে যান

What the customer sees, and why

The model never talks to the customer directly. The policy layer picks a tier, and the top SHAP drivers are translated into plain Bangla or English sentences. The LLM is not involved in this screen at all, so nothing here can hallucinate.

Second Thought

score 0.019 · human-likeness 1 · coercion pattern

The person looks genuine but the situation matches a scam pattern (first-ever recipient, unusual amount, hesitation). Talk to the customer, do not block them.

Ground truth: A3_coerced_victim

Second Thought

genuine person, scam-like situation. Explain, add a 30 s cooling period, offer an exit. Never block.

Stop-up: likely not the owner. Re-verify before the money call executes.

Hold: traffic is not the genuine app. Pause and queue for a human analyst.

reset phone

Reasons come from SHAP drivers through a fixed sentence map — Bangla or English. No LLM on this screen, so nothing can hallucinate to a customer.

Second Thought

Session-authenticity engine for MFS - scores the path to the transaction, not just the transaction

AUC 0.9998 recall 100% @ 2.0% friction stopped before money 92% API Live

Replay Theatre

Customer screen

Analyst console

Alert queue

held-out month, top by score

1.00	U01244	small_merchant	৳72,300
1.00	U00205	rmg_worker	৳69,800
1.00	U00984	rural_lowlit	৳68,500
1.00	U01331	rural_lowlit	৳67,800
1.00	U00709	salaried	৳64,600
1.00	U01277	rmg_worker	৳63,600
1.00	U00551	salaried	৳61,400
1.00	U01207	small_merchant	৳58,900
1.00	U01384	salaried	৳58,500
1.00	U02875	small_merchant	৳58,200

Case view

Scf597d775c U00396 Second Thought

score 0.019 · 18 events · fired at 16 · money call at 16

Why (SHAP, positive contributions)

total amount

23700

first-ever recipient

1

amount vs history

23700

checked balance

0

screens vs API calls

0.5

Policy: The person looks genuine but the situation matches a scam pattern (first-ever recipient, unusual amount, hesitation). Talk to the customer, do not block them.

Profile at the time: 8 prior sessions · 6 known recipients · usual hour 18.4

release

Write investigation summary

Ground truth (hidden from a real analyst): A3_coerced_victim

Account-role misuse

personal wallet acting as merchant/agent (L4)

user	p	inbound/30d	senders	cash-outs	round%	
U01106	student	1.00	448	421	38	71
U00220	salaried	1.00	360	249	40	85

AUC

0.9998

PR-AUC

0.9936

Recall @2% friction

100.0%

Stopped before money moved

92.5%

Median events to detect

8

Money protected (test month)

৳76,56,535

Recall by archetype at 2% false friction (%)

Rule baseline

Second Thought

Unsupervised only

Rule baseline false friction: 12.1% vs ours 2.0%. Rules miss the coerced victim (A3) almost entirely because the victim is the human.

Queue ranked by money at risk, SHAP reasons, policy rationale, the user's profile at that moment, one-click actions, and an LLM summary grounded only in the evidence JSON.

5

Caught before the money moves, with 2% friction on genuine users

Fraud stopped at or before the first money-moving request

92.5%

median detection at event 8 · median money call at event 13

Recall @ 2% false friction · AUC

100%

AUC 0.9998 · PR-AUC 0.994 · still 96.7% recall at 0.25% friction

Rule baseline on the same data

82.7%

at 12.1% friction — and only 25.8% of coerced victims

ARCHETYPE	OURS	UNSUPERVISED ONLY	RULES	STOPPED BEFORE MONEY	DETECT / MONEY EVENT
A1 Scripted ATO via reverse-engineered API	100%	100%	100%	100%	1 / 4
A2 OTP-relay / SIM-swap takeover	100%	84%	95%	100%	11 / 22
A3 Coerced victim on a scam call	100%	52%	26%	97%	14 / 18
A5 Gambling / fake-purchase laundering	100%	48%	98%	44%	14 / 11
A6 Emulator farm	100%	97%	100%	100%	8 / 14
A7 Adaptive attacker (human-like timing)	100%	100%	100%	100%	1 / 4

Synthetic data with injected patterns (documented): absolute numbers are optimistic; the relative results are the point.

Robust, fair, and honest about limits

"Attackers will just add random delays."

A7 is exactly that: log-normal human-like gaps plus replayed telemetry. Timing stops helping. Still caught at event 1 of every session, because the **path** (no screens, no PIN screen before /transfer) and the **user baseline** (first-ever recipient, 6σ amount) survive mimicry.

"What about an attack you have never seen?"

We removed A5 from training entirely. The supervised model still caught 33%; the **label-free** Markov + Isolation Forest layer caught 48%. With A5 labelled: 100%. That gap is why the system is layered, and why analyst labels close the loop.

"Won't slow elderly users get flagged?"

False friction on genuine users: elderly **0.8%**, rural low-literacy 1.6%, feature-phone 2.1%, students 1.6%, 56+ 1.0%. The baseline compares each user with *themselves*, so slow is normal for a slow user. Demographics are never inputs.

"Isn't this just velocity rules?"

Rules: 82.7% recall at 12.1% friction, 26% on coerced victims. Rules cannot see a genuine human in a scam; a per-user baseline can.

Privacy & security

Behavioural metadata only. No PII features. The LLM only ever sees our evidence JSON — no prompt-injection surface. Keys in env; the engine has no write access to ledgers.

Human oversight

Nothing is permanently blocked by a model. Hold and step-up go to a person with release / step-up / freeze / call. Every alert carries SHAP reasons and a rule trace.

Zero app changes on day one. A dial, not a switch.

Business impact (synthetic test month, 600 users)

₹80.1 lakh at risk across 399 fraudulent sessions · **₹76.6 lakh protected** before money moved · at 2% friction, ~250 genuine sessions saw a 30-second confirm screen; none were blocked.

Per 1M active users at a realistic 0.3% fraud session rate, the same ratios imply tens of crores protected per year and a measurable drop in dispute volume. We would validate those economics in shadow mode, not claim them now.

Why upay specifically

The data already exists in the step-tracker. The engine is a sidecar: no SDK, no new instrumentation. The policy tier becomes one synchronous call before `confirm`, p99 budget under 50 ms. Second Thought copy is Bangla-first for the users scams target most.

Six steps to real data

1. **Schema mapping** — event vocabulary ↔ existing analytics stream.
2. **Shadow mode, 2 weeks** — score, do not act; learn the true base rate; set the friction budget on the operating curve.
3. **Label bootstrap** — fraud cases and complaints become positives; the unsupervised layer proposes candidates.
4. **A/B the Second Thought screen** — cancelled-by-customer, completed-then-disputed, friction complaints.
5. **Integrate** — synchronous tier decision before confirm.
6. **Govern** — model card, monthly fairness report, drift monitors, retraining cadence from analyst labels.

Roadmap: sequence model (GRU) as L6, device-graph features, typed-decision layer for the tier choice.

Stop asking "is this transaction fraud?" Ask "is this the owner, using the real app?"

Second Thought · live demo, open repo, reproducible metrics, every prompt logged.

Python · LightGBM · SHAP · FastAPI · React · synthetic data only · built solo in 4 hours with Claude Code